

****SEE ALSO Newsletter of June 28, 2023****

[web doc no. 9902472]

****Provision of April 27, 2023****

****Register of Provisions****

No. 188 of April 27, 2023

****THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA****

In today's meeting, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, Members, and
Counsel Fabio Mattei, Secretary General;

****HAVING REGARD TO**** Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC (General Data Protection Regulation, hereinafter "Regulation");

****HAVING REGARD TO**** the Code regarding the protection of personal data
(legislative decree of June 30, 2003, no. 196), as
amended by legislative decree of August 10, 2018, no. 101, containing
provisions for the adaptation of the national
legal system to the aforementioned Regulation (hereinafter
"Code");

****HAVING REGARD TO**** the Guarantor's Regulation no. 1/2019
concerning "Internal Procedures of External Relevance aimed at
carrying out the tasks and exercising the powers of the Guarantor," published
in the Official Gazette on May 8, 2019, no. 106;

****HAVING REGARD TO**** the documentation on file;

****HAVING REGARD TO**** the observations made by the Secretary
General pursuant to Article 15 of the Guarantor's Regulation no. 1/2000;

****REPORTING**** Attorney Guido Scorza;

****WHEREAS****

1. The investigations carried out by the Special Privacy Unit of the Financial Police and the preliminary investigation conducted by the Office.

In the context of the controls planned by the Guarantor with
resolution no. 42 of February 14, 2019, the Special
Privacy Unit of the Financial Police, in
execution of the delegated inspection activity, conducted
checks between November 5 and 7, 2019, at
Benetton Group S.r.l. (hereinafter "Company")
regarding the processing of personal data for
marketing and profiling purposes.

Initially, some document-based investigations were carried out, sending, in particular,
a request for information on November 16, 2020, and
receiving the requested feedback on December 11
of the same year, particularly regarding the management
of cookies.

After examining the received documents, the Office, taking into account

the number and complexity of the legal and technical profiles involved, deemed it necessary to verify with a new on-site assessment the marketing and profiling activities in order to obtain a more complete and detailed picture.

2. First Contestation (September 29, 2021).

Pending the new inspection assessment, hindered by the restrictions caused by the Covid-19 pandemic, an administrative procedure was initiated on September 29, 2021, highlighting the following critical issues:

- a) with reference to the site familycard.benetton.com, the “informational banner regarding the use of cookies, both first-party and third-party (technical, marketing, and profiling),” had to be accepted without the option to deselect the types of cookies; moreover, the extended information did not mention the profiling cookies among those used, as indicated in the banner, but only the technical, direct marketing, and third-party marketing and retargeting cookies (minutes of operations carried out on November 5, 2019, pp. 4 and 5);
- b) regarding the site blackcard.sisley.com, despite presenting a “hyperlink ‘click here,’” the cookie banner incorrectly redirected to a blank page of the site (test area) and the cookie link present in the footer was lacking the related information; moreover, there was no form for expressing consent regarding the use of cookies (see operations carried out, cited, *ibid.*); in relation to these aspects, the Company, in responding to the aforementioned request for information of November 16, 2020, communicated that “[...]. As emerged during the inspection activities, a new technology for managing cookies was already being implemented. This technology was definitively implemented on the sites [...] in December 2019, with the adoption of the Cookiebot platform [...],” which “allows the user to independently manage the verification of the current consent status, the consent ID, the date of consent issuance, the modification of the consents given [...] and their revocation [...]”;
- c) contrary to what was indicated in the register of processing activities and in the information provided to the customer for joining loyalty programs (according to which the retention period for the data indicated would be limited to 2 years concerning both marketing and profiling), personal data of customers, holders of the loyalty card, were found in the management systems used by the company, along with information related to purchases dating back to 2015, as well as detailed data from receipts, points, and sold products even concerning subjects who did not express consent to profiling (minutes of operations carried out on November 6, 2019, p.10 and November 7, 2019, p.13);
- d) following a selective search on the Dynamics management system, it emerged that the company sent promotional emails to 13 customers after “the date of their unsubscription from Loyalty marketing” (minutes of November 7, 2019, p. 14, annex 15);
- e) similarly, from a selective search on management “ContactLab” it emerged that the company sent a “[...] marketing communication to 4,259 consumers enrolled in the Loyalty program whose consent to receive marketing communications

(DB Dynamics) was prior to the date of unsubscribing from the online Newsletter [...]", and therefore also after the revocation of consent to receive promotional communications (minutes of November 7, 2019, p. 15, annex 16 and certified email of November 18, 2019, point 1). Therefore, based on the above considerations, the Office, with the same communication of September 29, 2021, contested to the Company the alleged violation of the following provisions:

- art. 13 of the Regulation; art. 6 of the Regulation and art. 122 of the Code, also in light of what is indicated in the provision of the Guarantor of May 8, 2014 "Identification of simplified methods for information and acquisition of consent for the use of cookies" (in G.U. no. 126 of June 3, 2014), with regard to what is represented in the aforementioned letters a) and b);
- art. 5, par. 1, letters c) and e), of the Regulation, with regard to what is indicated under letter c);
- art. 6 of the Regulation and art. 130 of the Code, with regard to the violations referred to in letters d) and e).

3. The Company's memorandum of October 27, 2021.

The Company – in relation to this first contestation – sent a defensive memorandum on October 27, 2021, in which it preliminarily highlighted how, in its opinion, "the notification of the communication of the alleged violations in question was carried out by this Authority beyond the term of 120 days from the date of the ascertainment, as provided for by Table B, no. 2), of Regulation no. 2/2019 of the Guarantor, stating 'the irreparable lateness of the notification of the allegations made against the Company ...', as it occurred '... almost two years after the inspection findings of the GdF (see minutes of November 5-7, 2019 and supplementary communication from Benetton of November 18, 2019) and almost a year from the response provided by Benetton to the last request for information from this Authority (see note GDPD of November 16, 2020 and Benetton's response of December 11, 2020)'."

In this regard, Benetton, while also representing the most favorable jurisprudential orientations for the extension of this term, ultimately argued the contradiction of the contestation formulated by the Authority with the "cited principles of appropriateness and reasonableness affirmed by the Supreme Court in the matter, rendering the contestation of the aforementioned violations completely untimely and late, with consequent invalidity and annulment of any subsequent sanctioning provision." Therefore, the same Company requested the archiving of the initiated procedure.

The Company, with the same memorandum, confirmed that it had already completed the implementation activities of organizational and technical measures aimed at overcoming the possible critical issues identified during the inspection (see statements on the layout "Cookie Consent – deploy November 2019", p. 5 of the minutes and on the initiated process of migration and unification of databases, p. 9, cited minutes), implementing "a new cookie management technology by users, with the adoption of the Cookiebot platform, aimed at allowing the user to independently manage any consents given, also producing the new texts for banners and information." Based on what was represented by Benetton "the implementation process (which started already in July 2019) of the Unique Database project was aimed at rationalizing, centralizing, and ensuring the correct management of data and consents of loyalty card members" and the "critical issues that emerged during the inspection were overcome, specifically with regard to both the possible data retention issues ... and the anomalies that emerged during the inspection (minutes of November 7, 2019) regarding the sending of commercial communications to the interested parties subsequently 'after the date of their unsubscribing from the Loyalty marketing' or 'from the online Newsletter service'."

Benetton, regarding the organizational and technical measures implemented, therefore represented – in the absence of remarks on this matter from the Authority in the communication of September 29, 2021 – that it could "infer that they have been deemed adequate or in any case sufficient ... thus excluding the need ... to adopt the corrective and sanctioning measures referred to in art. 58, par. 2, of the GDPR and being able, conversely, to lead to the archiving of the procedure."

With specific regard to point 2.1 of the contestation, Benetton argued that the cookie banner related to the site familycard.benetton.it, which "was to be accepted without being able to deselect the types of cookies," would have been set in accordance with what was provided in the cited General Provision of May 8, 2014, which constituted the reference point at the time of the contested facts (see cited

memorandum for more detail).

Regarding the further aspect concerning the failure to indicate in the extended cookie information of the site familycard.benetton.com the "profiling cookies, such as those indicated in the banner of the same site, but only those technical, direct marketing, marketing, and third-party retargeting," Benetton also highlighted that, according to its interpretation of the cited General Provision, "since profiling cookies are defined as cookies aimed at creating profiles related to the user and that are used to send advertising messages in line with the preferences expressed by the same during web browsing..., what is indicated in the 'cookie policy' of the Benetton site, regarding the use of cookies of direct marketing, marketing, and third-party retargeting constituted nothing more than a specification of the profiling cookies used."

In relation to point 2.3 of the complaint, Benetton stated "that the retention of data concerning the data subjects who hold loyalty cards, along with related receipts and so on, pertained to a purely contractual plan (e.g., recognition of the correctness of the points awarded and the rewards granted to members, etc., see also what is indicated in the minutes of operations carried out on November 5, 2019, p. 6), for which... the relevant record of processing (see Annex 5 to the minutes of operations carried out) provided, in fact, for a retention period of 10 years (see also the notices referred to in Annex 1 to the minutes of operations carried out which indicated as the retention period the duration of the loyalty program – while for consents, reference was made to 2 years), and was independent of any processing carried out for profiling purposes, as well as for marketing (which was only carried out in the presence of valid consents for such purposes)."

With reference to what is indicated in points 2.4 and 2.5, the Company reiterated "(in line with what was already expressed during the inspections and the subsequent supplementary checks of the Company) that (i) the systems dedicated to the issuance and management of loyalty cards, (ii) those dedicated to the management of so-called digital customers, and (iii) those used for the management of the so-called Newsletter... responded to different logics and, moreover, were constituted and managed based on different documentation submitted to the data subjects, so that the notices dedicated to these latter and any consents given by them (or the oppositions expressed) during the adhesion or in the management of the relationship related to the individual service were not comparable. This was also reflected conversely, e.g., where a particular data subject had denied consent to receive direct marketing communications in the context of a digital purchase but then had subscribed to the newsletter, the same would not receive commercial communications other than the newsletter."

In light of all that has been stated and documented, the Company requested "the archiving of the procedure, also concerning the application of an administrative pecuniary sanction for the alleged violations subject to contestation, or in any case to proceed with the definition of this procedure pursuant to Articles 4, paragraph 3, and Article 14, paragraph 5, of Regulation No. 1/2019, considering that the conduct contested to the Writer, dating back to 2019, has exhausted its effects or such effects have been removed by Benetton... or in any case to determine the amount of any sanction at the minimum deemed applicable...", reserving the possibility of judicial appeal.

4. Inspection carried out by the Authority and related outcomes.

The Authority, in order to verify the concrete implementation of certain measures proposed by the Company in the defense memorandum of October 27, as well as for an assessment, including of a technical nature, on the corporate systems and databases and more broadly on the processing for marketing and profiling purposes - taking advantage of an improvement in the pandemic situation that had allowed for the resumption, albeit limited and with the adoption of precautions, of circulation within the Italian territory and therefore also the carrying out of on-site checks - conducted, on the dates of November 8-10, 2021, an inspection at the company headquarters.

On this occasion, it was possible to gain direct knowledge of the measures implemented by the Company, finding compliance with the relevant regulations, with specific reference to the management of cookies, the corporate CRM, as well as promotional communications (as proposed by the Company

in the memorandum of October 27, 2021).

Based on the overall examination of the checks carried out, as well as the clarifications provided by the Company in the same circumstance, the following possible violations emerged.

A) Violation of Article 5, paragraph 1, letters c) and e), of the Regulation

From the checks carried out on-site, it emerged (Annex 11, minutes of November 9, 2021) that the personal data (name, surname, gender, date of birth, email address; phone number) of XX ("online newsletter pure inactive") were retained, despite having deactivated the newsletter service concerning them and, as far as the documents show, in the absence of justifying reasons for such retention. Moreover, the Company represented that "the unsubscribed individuals in 2021 from the Newsletters are 2,318" (Annex 21).

Furthermore, it was found that "the records of all those customers/ex-customers who have not requested the deletion of their account, or who have not made specific requests for anonymization" were "present in the system" (see minutes of November 8, 2021; similarly, it is indicated in the notice provided to the data subjects pursuant to Article 13 of the Regulation: Annex 2 to the said minutes), leading to the presumption of a retention of such data - except for those related to transactions for which the same policy provides for deletion after 24 months - potentially indefinitely.

Therefore – without prejudice to the quantitative aspect, which on the occasion of the new complaint the Authority invited the Company to clarify – the conditions for the violation by the Company of Article 5, paragraph 1, letters c) and e), of the Regulation (principles of minimization and limitation of retention) were identified.

B) Violation of Article 32, paragraph 1, letters b) and d), and par. 2, of the Regulation.

Regarding the procedure for creating a store profile on the Dynamics platform, in which the access password for the related account is sent via email to the District Manager (i.e., the person responsible for coordinating multiple stores), who then forwards it to the relevant store manager, it has emerged that "the password change is not mandated by the system." Furthermore, "the store account password is unique for all employees of the single store" (minutes 9.11.2021).

It has also been noted (minutes cited above) that:

- the PC in use at the store does not have specific operational limitations (screenshots can be taken, etc.);
- since the platform related to the loyalty cards is accessible via a web link, it can be accessed from any device (smartphone, tablet, PC), provided that the policy of accessing exclusively with the tools provided for the relevant duties is respected (exclusively from store PCs);
- the account in question allows all employees of the same store to view customer data from stores in the 7 European countries where the Benetton Group srl loyalty program is present, enabling customers to accumulate points related to their purchases regardless of their nationality, also because the point allocation policy in question is the same in all said countries (1 point = 1€);
- the employee can access the loyalty program regardless of whether they are logged into the cash register system (in fact, access to the portal related to the loyalty cards is independent of access to the cash register, for which each operator has different and specific access credentials);
- regarding the creation of the user account for a new store, on the loyalty side, the system does not require a password change; however, it is suggested, as a practice, to change it after the first access;
- in response to a specific request from the minutes takers regarding "the performance of audits on the processing of data by Benetton stores managed by Retail Italia Network Srl (part of the corporate group), as well as on the processing carried out by Co-marketing partners, the Company stated that 'so far no audits have been conducted, but they are currently being planned.'"

Based on the overall examination of the above, the conditions have been identified to consider the violation of art. 32, par. 1, letters b) and d), and par. 2, of the Regulation, regarding the "ability to ensure on a permanent basis the confidentiality ... and integrity" of the processed data and to guarantee "a procedure to regularly test, verify, and evaluate the effectiveness of technical and organizational measures to ensure the security of processing." (see par. 2: "In assessing the

appropriate level of security, particular consideration is given to the risks presented by processing that arise particularly from destruction, loss, alteration, unauthorized disclosure, or accidental or unlawful access to personal data transmitted, stored, or otherwise processed.").

C) Violation of arts. 5, par. 2, and 24, of the Regulation.

Finally, regarding the issue of communications of personal data to third parties for marketing and profiling purposes, the Company referred to TikTok and Facebook as commercial partners in such activities. However, despite the specific requests made by the Office (see minutes of November 9, 2021), the relationship with these platforms regarding the data processing carried out in the name and/or on behalf of Benetton remained poorly defined and unclear, considering that Benetton provided only a copy of the standard terms of service issued by these two third-party companies to the generality of their users, without explaining or producing documentation regarding their role in the data processing and any operational instructions given to them. This has led to the assumption of a possible violation of the accountability principle (arts. 5, par. 2, and 24, of the Regulation).

The aforementioned alleged violations were subject to a new further contestation on March 11 of this year.

5. The Company's memorandum of April 11, 2022.

On April 11 of this year, the Company sent a defensive memorandum, in which it highlighted its intention to provide "elements, integrations, and clarifications necessary for the assessment of the reasons why it is believed that the need for the application of any corrective and sanctioning measures in this case should be excluded, also in light of the measures adopted or being adopted by Benetton ...".

Regarding the potential violations indicated in letter A) of the Contestation, it stated that:

"With reference to Ms. XX, her personal data is still present in Benetton's systems, despite her deactivation from the newsletter service, as she is still the holder and user of our loyalty card. In particular, the interested party registered for the loyalty card program in 2012 (using, moreover, the related email address as user ID) and for the newsletter service in 2017. As already mentioned, between 2019 and 2020, the so-called 'unique database' was implemented, within which the creation of a single record related to the individual interested party was provided, containing all the relevant information regarding the registration for Benetton services (Newsletter, Loyalty card, e-Commerce). In this database, there is thus a unique, specific record.

referred to Ms. XX, as she is still the holder of the fidelity card (which she uses regularly) and it is also noted in the same record that the newsletter service has been deactivated." (see attachment 1 to the memorandum of April 11, last).

Regarding the different profile concerning the presence, in Benetton's systems, of data related to customer records who have not requested the cancellation of their account or who have not made specific requests for anonymization, "as similarly indicated in the information provided to the data subjects," the Company observed that "in relation to the registration for the e-commerce service (necessary for making purchases) and the registration for the fidelity card program, these services have been structured without a predetermined duration or expiration date, in order to allow the user to benefit from them continuously over time, also considering the type of products offered by the Company and the frequency of customer purchases, which are generally made even after a period of time. It should also be noted that, since there is an automatic process for deleting data related to transactions or purchases older than 24 months, it would theoretically not be possible to reconstruct whether the customer has never made transactions or if they have made transactions that have been deleted by the described process. Hence the indication of maintaining the customer account in the systems until the latter requests (i) the deactivation of the service/account or (ii) the deletion of personal data from the archives (in cases of unsubscription or deactivation, the data subjects can be considered as "former customers").

The Company then added that: "In any case, ... considering the historical depth of the older data related to the aforementioned services, ... it intends to define a maximum duration for the retention of customer data related to registration for the aforementioned services, in the event of their inactivity in the last 24 months, to be set at a maximum term of 10 years from the date of the same registration (in this sense, the information provided to the data subjects will be updated). This would also allow for the

preservation of the legitimate needs of the Company to maintain, for said period (substantially aligned with the time frame legally provided for the retention of contractual documents), the data of customers adhering to the aforementioned services, which are essential also for the purpose of being able to defend itself in the event of any subsequent disputes (in recent years, there have indeed been some disputes with the data subjects, in relation to which, if the data had been completely deleted, Benetton would not have been able to protect its rights....). Also for the newsletter service, it is planned to proceed with data retention for 10 years, subject to the provision of an automatic deactivation system in case of failure to send communications by the Company or inactivity of the data subject for 24 months, and without prejudice to the possibility of requesting the deactivation of the service and the deletion of the data. As requested, it is also communicated that, to date, the total number of subscribers only to the newsletter, who are reported to have deactivated the service, is 249,859. It is confirmed that, in cases of registration exclusively for the newsletter, only data related to email addresses and privacy consents provided by users are retained.”

With reference to the potential violations indicated in letter B) of the Contestation, the Company represented that: “Regarding the creation of a store profile on the Dynamics platform, it should be noted that, from a technical point of view, the system does not allow setting the password change for that profile as mandatory and, for this reason, recommendations have been provided to encourage the password change at the first access (see the cash procedure provided by the company to the store manager, in addition to what was communicated at the time of delivering the credentials), in line with what has already been provided in the instructions given more generally to authorized persons (former data processors) within the framework of the company policies and documentation already in the records. To address the aforementioned technical limitations, activities have already been initiated to replace the platform with a new one that will also have the specific functionality of making the password change mandatory. This activity will be completed in the coming months, before the end of the year. In any case, to further strengthen the aforementioned indications and instructions during this transitional period, it has also been planned that, at the time of communicating the password to the store manager (separately from the communication of the username), there will also be a specific reminder of the obligation to change it at the first access (obviously the changed password is no longer visible), as well as that, periodically, a communication will be sent to remind compliance with this obligation.”

Benetton also highlighted: “that the Dynamics platform, while providing a unique account for each store, allows for view-only access to the data of the data subjects, without the possibility of modification (except for the possibility of creating new fidelity cards) and that the operations performed with this account are nonetheless tracked through appropriate logs, which are retained in the system for an appropriate period of time, thus allowing for specific audits to be conducted, either randomly or in case of any reports of anomalies; that as of the date of the memorandum in question, no “complaints or disputes from customers regarding the aforementioned platform have been received. In any case.... through the activation of further, specific interventions.

****Technical Implementation of User Access on Dynamics Platform****

A process has been successfully implemented that provides for the assignment of user accounts on the Dynamics platform with individual credentials for each store employee. The Dynamics platform necessarily allows access via a web link as it oversees the management of loyalty cards, including the customer side that accesses it (like the stores), while maintaining the different IT authorizations and permissions related to the respective accounts (the customer will only be able to consult information related to themselves, while store employees will be able to view a broader set of information (related to members of the loyalty program) for the operational management of loyalty cards and to allow each store to verify the points assigned to the customer, where necessary).

The Company has also highlighted that “the system allows access to the data of all members of the loyalty card service (from the stores in the 7 European countries where the program is present), as the service is unique and customers can accumulate points in any store, regardless of where it is located (customers traveling can make purchases in any country where a store is present). Furthermore, access to the Dynamics platform is independent of that of the cash register system, as these are

distinct systems, both managed in the cloud, and due to purely technical constraints and limits, it is not possible to block access from devices other than those used for the cash register, even though, as also reported by this Authority, store employees are required to use store PCs, as indicated in the company policy. Regarding the last statement concerning the conduct of specific audits on Benetton sales points, it is specified that, as mentioned, these have been postponed also due to the noted pandemic situation and that the internal audit function of Retail Italia Network s.r.l. has recently initiated some audits on compliance with security procedures (also concerning the management of information security) and is tasked with carrying out the audit plan related to privacy procedures being prepared by the Company within this year. That said, the Company reiterated that it has not received reports or complaints of any anomalies or irregularities from the stores and their respective employees regarding the aspects highlighted above.

Regarding the potential violations indicated in letter C) of the Contestation, specifically referring to the relationships with Facebook and TikTok, the Company clarified “that, due to a mere material error, also due to the particular moment of excitement related to the complex activities of gathering, verification, and delivery of the requested documentation during the inspection, documents acquired online related to the general terms of service for consumer customers were delivered in attachment 22, instead of those related to the business service contracts to which Benetton had adhered, which are attached hereto (see attachment 2) - as can be easily imagined, these are adhesion contracts, unilaterally drafted by the parties, regarding which the negotiating power of the adherent is rather limited. In any case, it is specified that, regarding what is overall provided by such contractual conditions, the competent functions of the Company have activated the so-called insertion or publication services of advertisements or, better, advertising banners that do not involve any processing of personal data ‘in the name and/or on behalf of Benetton’, nor any communication of personal data between Benetton and the aforementioned parties, maintaining distinct ownership of the processing concerning the respective areas and activities of competence. Essentially, like other operators in the sector, Benetton limits itself to preparing advertising content and purchasing the “spaces” or advertising areas managed exclusively by these parties, using only the services that provide for the insertion of banners within the respective platforms, without providing personal data of customers or users, nor receiving personal data about the users who view them.”

In light of the elements and documents provided regarding the measures adopted, Benetton has requested “the archiving of the further proceeding under examination, also concerning the application of any administrative pecuniary sanction” and “in any case to determine the amount of any sanction at the minimums deemed applicable,” recalling, in addition to the elements outlined above, “the statements made at the conclusion of the inspection report of November 10, 2021, regarding the attention maintained by the complex corporate organization to privacy aspects and safeguards even during particularly difficult years due to the noted situation of health emergency and the socio-economic crisis.”

****6. Overall Observations of the Authority in Light of the Two Memoranda from the Company.****

****6.1. The Alleged Violations Challenged with the Communication of September 29, 2021.****

With reference to the defense formulated by the Company in the first memorandum (October 27, 2021), it should first be noted that the timing of the verification by the Office, which since the acquisition of the documents has deemed necessary its own verification activity on-site, to complete and clarify the operations already conducted by the Special Privacy Unit of the Guardia di Finanza in November 2019, has been determined by the pandemic emergency that manifested itself since the beginning of 2020.

The Office therefore only made requests for documentary information while waiting for the noted limitations on free movement imposed by government regulations to end, as well as – once gradually reduced the same – the attenuation of the risk of contagion from Covid-19, for the protection of individual health and public health. In this exceptional context, the ex lege suspension of all deadlines related to the conduct of administrative proceedings pending as of February 23, 2020, or

initiated after that date, for the period between this date and May 15, 2020 (extension provided by Article 37, Legislative Decree No. 23/2020, paragraph 1) is inscribed. That said, the notice of contestation dated September 29, 2021 – despite what the Company believes and precisely in light of a ruling by the Supreme Court cited in its own memorandum of October 27 of this year – cannot certainly be considered untimely, as it is significantly conditioned both by actual needs for verification and understanding of the processing dynamics of Benetton and by the exceptional and well-known conditions of limitations and uncertainty related to the pandemic emergency. It should also be considered that – as recalled by the recent provision of the Guarantor dated December 16, 2021, document web No. 9735672 – in general, regarding the activities of independent administrative authorities, the Supreme Court (Cass. Civ. Sec. 2, No. 31635/2018), reiterating arguments previously expressed, has reaffirmed that “the activity of ascertaining the unlawful act, in relation to which to place the dies a quo of the term for the notification of the details of the violation, cannot coincide with the moment in which the fact is acquired in its materiality, but must be understood as inclusive of the time necessary for the evaluation of the data acquired and relating to the (objective and subjective) elements of the infringement and, therefore, of the final deliberation phase related to the complexity, in this case, of the investigations aimed at verifying the existence of the infringement itself and acquiring full knowledge of the unlawful conduct, so as to assess its consistency for the correct formulation of the contestation (cf. Cass. No. 13050/2014; Cass. No. 1043/2015 and Cass. No. 770/2017).” Similarly, with specific reference to the administrative violations under the Privacy Code, the Supreme Court has recently reiterated that (Cass. Civ., Sec. 2, No. 18288/2020) “it is established that the orientation of this Court is such that, regarding administrative violations under the Privacy Code, the dies a quo for calculating the ninety-day term for the notification of the contestation report starts from the ascertainment of the violation, which does not coincide with the generic and approximate perception of the fact and with the acquisition of the documentation related to it, but requires the processing of the data thus obtained in order to identify the constitutive elements of any violations (thus, among others, Cass. 14678/2018).” Although this jurisprudence refers to the 90-day term provided for by Article 14 of Law No. 689/1981, the principles identified therein can well find similar application in relation to Article 166, paragraph 5, of the Privacy Code, since this last provision, following the amendments made by Legislative Decree No. 101/2018, contains the new regulation regarding the procedures for the adoption of corrective and sanctioning measures, which had previously been defined exclusively through the reference made by the Code itself to the aforementioned Law 689/1981. It follows that “the time for the processing and evaluation of data, when not arbitrarily and unreasonably prolonged, will be directly proportional to the level of complexity of the cases subject to the procedure,” including also “the method of analysis applied by the Authority” (see provision of December 16, 2021, cited). However, it must be considered, as noted during the inspection conducted between November 8 and 10, 2021, that the time elapsed has allowed the Company to significantly improve compliance with current regulations regarding some relevant critical issues, which were the subject of the first contestation (see also memorandum of October 27, 2021, and cited inspection reports). This specifically refers to the renewed management of cookies as well as the implementation of the customer database, which currently allows for each of them a single record, with a single option of will – positive or negative – regarding processing for promotional purposes, even in the face of multiple services (fidelity card; e-commerce; subscription to the newsletter), all involving the sending of communications that are substantially promotional in nature. Thus, for example, if the interested party unsubscribes from the fidelity program, they should no longer receive promotional newsletters. Considering the systematic and radical corrective intervention made by the Company in the revision of the aforementioned treatments, this Authority believes it can proceed with the archiving of the aforementioned first contestation.

6.2. The alleged violations notified with the second contestation (March 11, 2022).

In light of the memorandum submitted by Benetton on April 11 of this year, it is deemed that the alleged violation of the principles of minimization and limitation of retention concerning the data of XX (letter A of the contestation) is not ascertainable, and therefore can be archived, as the Company clarified that the data in question “are still present in Benetton's systems, despite being deactivated by the same from the newsletter service, as the interested party is still the holder and user of our fidelity

card." Furthermore, it is also archivable, due to the reasons put forward by the Company and the specifics provided regarding the roles held by commercial partners, Facebook and TikTok, in the processing of personal data for marketing purposes, the contestation of the principle of accountability. **Regarding the data processing carried out by the aforementioned companies, on behalf of and/or for Benetton (letter C of the notice). **

Conversely, while acknowledging the corrective measures that Benetton claims to have independently implemented, the violation of Article 5, paragraph 1, letters c) and e) of the Regulation (principles of minimization and limitation of storage) - as stated in letter A) of the same notice - must be confirmed concerning the indefinite retention of certain data of former customers (unsubscribed or deactivated), also in light of the equally essential principle of purpose (see Article 5, cited, letter b). Moreover, as of the date of the memorandum of April 11 of this year, the total number of subscribers only to the newsletter, who were found to have deactivated the service, yet still retained by the Company, is significant (249,859). This critical issue connects to the similar point 2.3 of the first notice, which also concerns the violation of the principles of minimization and limitation of storage, thus revealing persistent issues in this regard, especially since there do not appear to be specific corrective measures already implemented by the Company, particularly regarding the details of receipts. In light of this, the ten-year duration of the retention of the same, especially if rich in details objectively related to the tastes and preferences of the data subjects - even if used by the Company for marketing or profiling purposes only with prior specific consent - is to be considered clearly excessive compared to the measure of 12 months/24 months, indicated, concerning the aforementioned purposes, in the general provision "Fidelity card and guarantees for consumers. The rules of the Guarantor for loyalty programs" - February 24, 2005, web document no. 1103045, also in light of the principles of accountability and "general responsibility" (according to Articles 5, paragraph 2 and 24, as well as Cons. no. 74, of the Regulation).

Considering all of this, it is deemed necessary to adopt, against the Company, a corrective measure with which:

- to order the deletion or anonymization of the personal data of former customers dating back to a period exceeding 10 years, except in cases where a judicial or extrajudicial dispute is still ongoing;
- to order the adoption of suitable organizational and technical solutions aimed at ensuring that the retention of data of customers and former customers occurs in compliance with the principles of Article 5 of the Regulation, and in particular of purpose, minimization, and limitation of storage.

It must also be confirmed, concerning Benetton, the violation of Article 32, paragraph 1, letter b), also in light of the provisions of paragraph 2 of the Regulation, as stated in letter B) of the notice, regarding:

- the procedure for creating a store profile on the Dynamics platform;
- the lack of specific limitations in terms of operations (screenshots or similar operations can be performed) of the computer in use at the store;
- the possibility of accessing the platform related to the loyalty cards reachable via web link, from any device (smartphone, tablet, pc);
- the possibility for the employee to access the loyalty program regardless of whether they have logged into the cash register system;
- the lack of a requirement for a mandatory password change at the time of creating the account related to a new store, loyalty side, and the uniqueness of the store account password for all employees of the single store (minutes of November 9 of this year), and therefore, consequently, the lack of possibility to identify the person actually responsible for any 'data breach'.

In fact, according to the aforementioned regulation, "taking into account the state of the art and the costs of implementation, as well as the nature, object, context, and purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons, the data controller and the data processor implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which include, among others: ... b) the ability to ensure on a permanent basis the confidentiality of the data." Furthermore, according to paragraph 2, "in assessing the appropriate level of security, particular attention is paid to the risks presented by the

processing that arise in particular (also) from unauthorized disclosure or access, in a manner that is accidental or unlawful, to personal data transmitted, stored, or otherwise processed."

Moreover, it must be considered that the violation of Article 32, paragraph 1, letter d), is confirmed, as there was a lack of "a procedure to test, verify, and regularly evaluate the effectiveness of technical and organizational measures to ensure the security of processing." These violations, moreover, fall within the general principles of 'security' and 'confidentiality' of Article 5, paragraph 1, letter f), of the Regulation, of which there is a need to ensure timely and effective protection, also to prevent the factual conditions for potential data breaches from occurring. In this regard, it is essential to observe that the violation of Article 32 of the Regulation does not constitute an offense of 'event damage,' but an offense of 'danger,' therefore - to integrate it - it is sufficient to ascertain the existence of the conditions provided by the European legislator, without the need for a personal data breach to have occurred, which is indeed governed by specific distinct norms (33 and 34, Regulation).

****6.3. Overall Findings and Consequent Measures to be Adopted.****

Overall, from this ascertainment of the unlawfulness of the Company's conduct concerning the treatments examined, it is deemed necessary, with respect to Benetton: pursuant to Article 57, paragraph 1, letter f), of the Regulation, to declare unlawful, in the terms set out in the reasoning, the processing carried out by the Company; particularly due to the violation of the following provisions:

- Article 5, paragraph 1, letters c) and e), of the Regulation;
 - Article 32, paragraph 1, letters b) and d), and paragraph 2, of the Regulation;
- pursuant to Article 58, paragraph 2, letter g), of the Regulation, to order the deletion or anonymization of the personal data of former customers dating back to a period exceeding 10 years, except in cases where a judicial or extrajudicial dispute is still ongoing, within 10 days from the date of receipt of this provision;
- pursuant to Article 58, paragraph 2, letter d), of the Regulation, to order the adoption of suitable organizational and technical solutions aimed at ensuring that the retention of data of customers and former customers occurs in compliance with the principles set out in Article 5 of the Regulation, and in particular of purpose, minimization, and limitation of retention, within 30 days from the date of receipt of this provision;
- pursuant to Article 58, paragraph 2, letter d), of the Regulation, to order the same Company to adopt suitable organizational and technical solutions aimed at ensuring that the management of personal data of customers, by store personnel, occurs in compliance with Article 32, paragraph 1, letters b) and d), and paragraph 2, of the Regulation, within 30 days from the date of receipt of this provision;
- pursuant to Article 157 of the Code, to request the same Company to provide adequately documented feedback regarding the aforementioned measures, within 40 days from the date of receipt of this provision;
- to adopt an injunction order, pursuant to Articles 166, paragraph 7, of the Code and 18 of Law No. 689/1981, for the application of the administrative monetary sanctions provided for by Article 83, paragraphs 4 and 5, of the Regulation.

****7. Injunction Order for the Application of the Administrative Monetary Sanction.****

With limited reference to the second allegation sent to the Company, it should be noted that the violations confirmed above (see paragraph 6.3) require the adoption of an injunction order, pursuant to Articles 166, paragraph 7, of the Code and 18 of Law No. 689/1981, for the application against Benetton Group s.r.l. of the administrative monetary sanction provided for by Article 83, paragraphs 4 and 5, of the Regulation. However, since various provisions of the Regulation and the Code have been violated in relation to connected treatments carried out by the Company for marketing purposes, Article 83, paragraph 3, of the Regulation is deemed applicable, according to which, "if, in relation to the same processing or connected treatments, a data controller violates, with intent or negligence, various provisions of the Regulation, the total amount of the administrative monetary sanction does not exceed the amount specified for the most serious violation," thus absorbing the less serious violations. Specifically, the aforementioned violations—also concerning the principles of minimization and limitation of retention, as set out in Article 5 of the Regulation—are to be classified, pursuant to Article

83, paragraph 3 of the same Regulation, within the scope of the most serious violation, with the consequent application of only the sanction provided for in Article 83, paragraph 5, letter a), of the Regulation.

For the determination of the amount of the sanction, which must “in any case [be] effective, proportionate, and dissuasive” (Article 83, paragraph 1), it is necessary to take into account the elements indicated in Article 83, paragraph 2, of the Regulation.

In this case, the following aggravating circumstances must be considered:

1) the high number of affected individuals and the significant duration of the violations (letter a);
2) the subjective dimension of the conduct, to be considered seriously negligent due to the deviation of the conduct in light of the substantial regulatory activity of the Authority, with particular reference to the retention of data (letter d);

3) the economic significance of the Company (see turnover—“business volume” of €510,143,722.00, according to the “VAT model 2021” and €817,306,980.00, according to the “VAT model 2020”; letter k).
As mitigating factors, pursuant to Article 83, paragraph 2, of the Regulation, it is deemed necessary to take into account:

1) the measures proposed to improve compliance with data protection regulations.

(c);

2) the absence of previous proceedings initiated against the Company (letter e);

3) the collaboration and transparency demonstrated by the Company to the Authority during the inspection assessments and, more generally, in the context of the conducted investigation (letter f);

4) the official ascertainment of the aforementioned violations, in the absence of reports and complaints against the Company (letter h);

5) the pandemic emergency situation in which the assessment in question took place and, in particular, the financial losses represented by the Company (and also emerging from the significant negative variation in turnover amounting to 308,011,179: approximately -37%); as well as “the recourse to short-time work of one day a week for over a year” (see verb. November 10, 2021) (letter k).

Based on the complex of the elements indicated above, in application of the principles of effectiveness, proportionality, and deterrence indicated in Article 83, paragraph 1, of the Regulation, taking into account the necessary balancing between the rights of the interested parties and the freedom of enterprise, also in order to limit the economic impact of the sanction on the organizational, functional, and employment needs of the Company, it is deemed that an administrative sanction of a payment of 240,000 euros (two hundred forty thousand/00), equal to approximately 1.18% of the maximum administrative sanction (20,405,748 euros) should be applied to Benetton Group s.r.l.

In this case, it is also deemed that the accessory sanction of publication on the website of the Authority of this provision should be applied, as provided for by Article 166, paragraph 7, of the Code and Article 16 of the Regulation of the Authority No. 1/2019, taking into account the subject matter of the investigation with respect to which this Authority has adopted numerous provisions both of a general nature and directed at specific data controllers.

Finally, the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, for the annotation of the violations identified here in the internal register of the Authority, as provided for by Article 57, paragraph 1, letter u), of the Regulation, are met.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY

a) pursuant to Article 57, paragraph 1, letter f), of the Regulation, declares unlawful, in the terms set out in the reasoning, the processing carried out by Benetton Group s.r.l., VAT: 03490770264, with registered office at Via Villa Minelli, 1, Ponzano Veneto (Treviso);

b) pursuant to Article 58, paragraph 2, letter g), of the Regulation, orders the same Company to delete, or anonymize, the personal data of former customers dating back to a period greater than 10 years, except in cases where a judicial or extrajudicial dispute is still ongoing, within 10 days from the date of receipt of this provision;

c) pursuant to Article 58, paragraph 2, letter d), of the Regulation, orders the same Company to adopt

appropriate organizational and technical solutions aimed at ensuring that the retention of customer and former customer data occurs in compliance with the principles set out in Article 5 of the Regulation, and in particular of purpose, minimization, and limitation of retention, within 30 days from the date of receipt of this provision;

d) pursuant to Article 58, paragraph 2, letter d), of the Regulation, orders the same Company to adopt appropriate organizational and technical solutions aimed at ensuring that the management of personal data of customers by store personnel occurs in compliance with Article 32, paragraph 1, letters b) and d), and paragraph 2), of the Regulation, within 30 days from the date of receipt of this provision;

e) pursuant to Article 157 of the Code, requests the same Company to provide adequately documented feedback regarding the aforementioned measures, within 40 days from the date of receipt of this provision. It is reminded that failure to respond to the above requests constitutes the elements of the administrative offense referred to in Article 166, paragraph 2, of the Code;

ORDERS

Benetton Group s.r.l. to pay the sum of 240,000 euros (two hundred forty thousand/00), as an administrative pecuniary sanction for the violations indicated in the reasoning, stating that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by complying with the prescribed measures and paying, within thirty days, an amount equal to half of the imposed sanction;

ORDERS

the aforementioned Company, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of 240,000 euros (two hundred forty thousand/00), according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/1981;

DISPOSES

as an accessory sanction, pursuant to Article 166, paragraph 7, of the Code and Article 16 of the Regulation of the Authority No. 1/2019, the publication on the Authority's website of this provision and, pursuant to Article 17 of the Regulation of the Authority No. 1/2019, the annotation in the internal register of the Authority, as provided for by Article 57, paragraph 1, letter u) of the Regulation, of the violations and the measures adopted.

Pursuant to Article 78 of Regulation (EU) 2016/679, as well as Articles 152 of the Code and 10 of Legislative Decree No. 1

September 2011, No. 150, against this provision, an opposition may be filed with the ordinary judicial authority, by means of a petition submitted to the ordinary court of the place where the data controller resides, or, alternatively, to the court of the place of residence of the data subject, within the term of thirty days from the date of communication of the provision itself, or sixty days if the applicant resides abroad.

Rome, April 27, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei